

HiveForce Labs

THREAT ADVISORY

 **VULNERABILITY REPORT**

CVE-2025-13915: Authentication Bypass Puts IBM API Connect at Risk

Date of Publication

January 07, 2026

Admiralty Code

A1

TA Number

TA2026004

Summary

First Seen: December 17, 2025
Affected Product: IBM API Connect
Impact: IBM has disclosed a critical vulnerability in its API Connect platform, tracked as CVE-2025-13915, that allows remote attackers to bypass authentication and gain unauthorized access without user interaction. API Connect, a core enterprise solution used to manage and secure APIs across cloud and on-premises environments, is often deeply embedded in organizational infrastructure, amplifying the impact of this flaw. Successful exploitation could grant attackers elevated access to the application, putting sensitive data, services, and connected systems at risk.

⚙️ CVE

CVE	NAME	AFFECTED PRODUCT	ZERO-DAY	CISA KEV	PATCH
CVE-2025-13915	IBM API Connect Authentication Bypass Vulnerability	IBM API Connect	✗	✗	✓

Vulnerability Details

#1 IBM has disclosed a critical security vulnerability in its API Connect platform, identified as CVE-2025-13915, which exposes the application to remote compromise. The flaw allows an attacker to bypass authentication controls, granting unauthorized access without requiring user interaction.

#2

API Connect is IBM's comprehensive API management solution, designed to help organizations build, test, manage, and secure APIs across both cloud and on-premises environments. Because it often sits at the core of enterprise integrations, its exposure significantly elevates risk.

#3

The vulnerability is remotely exploitable and can be used to gain direct access to the application with elevated privileges. If exploited, attackers could compromise sensitive data, services, and connected infrastructure.

Vulnerability

CVE ID	AFFECTED PRODUCTS	AFFECTED CPE	CWE ID
CVE-2025-13915	IBM API Connect V10.0.8.0 - V10.0.8.5, V10.0.11.0	cpe:2.3:a:ibm:api_connect:*:*:*:*:*	CWE-305

Recommendations



Apply Interim Fixes Immediately: Organizations running affected versions of IBM API Connect must prioritize the deployment of IBM's released interim fixes (iFixes) without delay. These patches directly address CVE-2025-13915 and represent the definitive remediation for the authentication bypass vulnerability. Access the appropriate fix from IBM Fix Central based on your specific API Connect version, extract the provided files, including the README documentation and the IFIX tarball, and follow IBM's detailed application instructions available on the support page for node 7255318.



Implement Temporary Mitigation for Deferred Patching: For environments where immediate patch deployment is operationally infeasible, IBM recommends disabling self-service sign-up functionality on the Developer Portal as an interim risk reduction measure. This configuration change limits the potential attack surface by removing one avenue of unauthorized access exploitation. However, this mitigation should be considered strictly temporary, as it does not fully resolve the underlying vulnerability and may impact legitimate user registration workflows.



Conduct Comprehensive Access Log Review: Analysis of authentication logs and access records for IBM API Connect instances to identify any anomalous access patterns or suspicious authentication events that may indicate prior exploitation attempts. Particular attention should be directed toward unusual successful authentications, access from unexpected geographic locations or IP ranges, and any administrative actions performed outside normal operational hours or user behavior baselines.



Strengthen Network Segmentation Controls: Review and reinforce network segmentation policies governing access to IBM API Connect infrastructure. Implement strict network access controls limiting connectivity to API Connect management interfaces to authorized administrative networks only, reducing the attack surface available to potential external adversaries. Consider deploying web application firewalls with rules configured to detect and block authentication bypass attempt patterns.



Potential MITRE ATT&CK TTPs

Tactic	Technique	Sub-technique
Initial Access	<u>T1190</u> : Exploit Public-Facing Application	
Defense Evasion	<u>T1562</u> : Impair Defenses	<u>T1562.001</u> : Disable or Modify Tools
Credential Access	<u>T1556</u> : Modify Authentication Process	
Persistence	<u>T1136</u> : Create Account	





Patch Link

<https://www.ibm.com/support/pages/node/7255149>



References

<https://www.csa.gov.sg/alerts-and-advisories/alerts/al-2025-126/>

<https://socradar.io/blog/ibm-api-connect-auth-bypass-cve-2025-13915/>

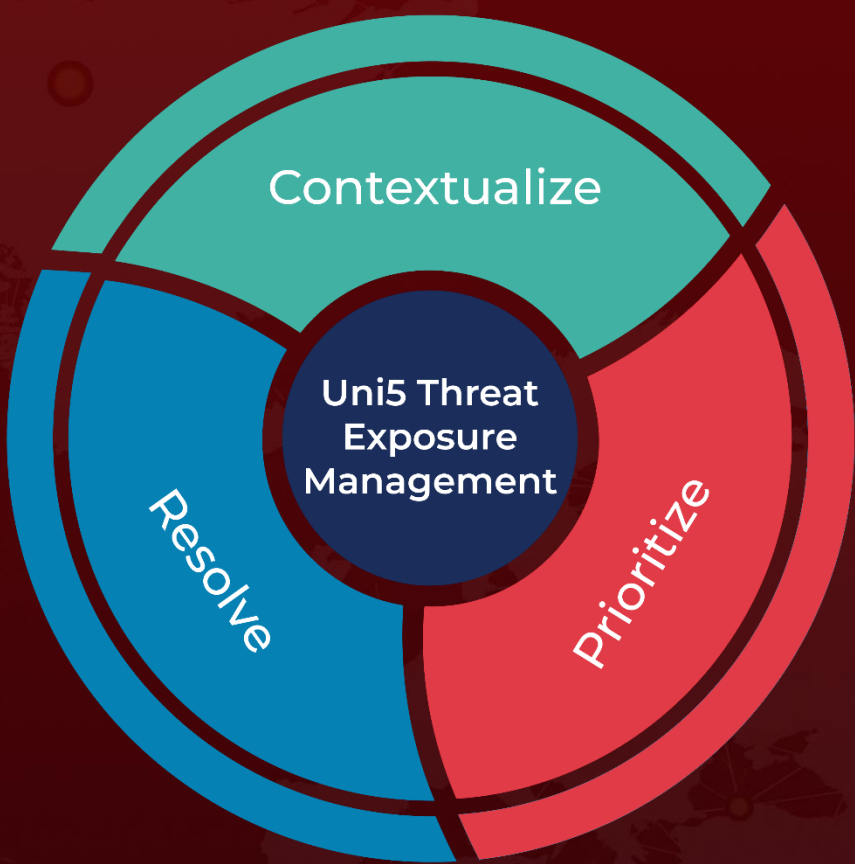
<https://cyble.com/blog/cve-2025-13915-ibm-api-connect-vulnerability/>



What Next?

At Hive Pro, it is our mission to detect the most likely threats to your organization and to help you prevent them from happening.

Book a free demo with HivePro Uni5: Threat Exposure Management Platform.



REPORT GENERATED ON
January 07, 2026 • 03:00 AM

